

Gestão de Cibersegurança

Universidade do Minho

2025/2026

Practical Lab Exercises #05

pg60986 — João Afonso Carneiro Araújo e Silva — MCS

pg59797 — Rui Pedro Ramos Carvalho — MCS

pg60307 — Tiago Leal Baganha — MCS

1.

Política de Segurança da Informação

1. Objetivo

O objetivo desta política de segurança da informação (PSI) é estabelecer os princípios, responsabilidades e requisitos necessários para garantir a **confidencialidade** das informações, a **integridade** dos dados, a **disponibilidade** dos sistemas e a **conformidade legal** das informações clínicas.

Esta política define o referencial de segurança aplicável ao uso da Cloud na organização, abrangendo os requisitos técnicos e organizacionais.

Os objetivos específicos incluem proteger os dados dos pacientes contra acesso, alteração e divulgação não autorizada e assegurar a conformidade com os regulamentos RGPD e HIPAA.

2. Âmbito

Esta política de segurança de informação aplica-se a todas as unidades, colaboradores, prestadores de serviços, parceiros, entidades terceiras que utilizam o sistema Cloud de gestão de pacientes e respetivos dados.

A aplicação abrange:

- Todos os utilizadores internos e externos com acesso às informações clínicas, administrativas e pessoais, como por exemplo, CIO, CCO, CISO, utilizadores internos, pacientes e fornecedores de Cloud.
- Todos os dados, suportes, equipamentos, redes e serviços associados à gestão e proteção da informação em ambiente Cloud.
- Todas as fases do ciclo de vida da informação, desde a recolha até à eliminação segura, assegurando a confidencialidade, integridade, disponibilidade e conformidade legal dos dados tratados.
- A utilização da informação destina-se a fins clínicos, administrativos (faturação e operações de receção), de gestão (supervisão, coordenação e melhoria de serviços), de investigação médica e de validação de sinistros e reembolsos por companhias de seguros.

3. Definições

- **Confidencialidade:** assegurar que a informação é acessível somente por pessoas devidamente autorizadas. O acesso à informação é, por conseguinte, restrito a utilizadores considerados legítimos.
- **Integridade:** garantir a veracidade, autenticidade e exatidão da informação, bem como os seus métodos de processamento ao longo de todo o processo, garantindo que o conteúdo não seja adulterado.
- **Disponibilidade:** assegurar o acesso à informação a quem se encontre devidamente credenciado e legitimamente autorizado. A informação está acessível quando se revelar necessária.
- **Conformidade legal:** a recolha da informação é feita nos estritos limites da lei é aplicável ao objeto da recolha.

4. Responsabilidades

Os utilizadores, incluindo todos os indivíduos que integram a estrutura institucional, são responsáveis por adotar um comportamento responsável e consistente com os objetivos da Segurança da Informação.

Neste sentido, é imperativo que todos estejam a par das normas e regras que regulam internamente o sistema de gestão da segurança da informação. Além disso, é essencial que se cumpra com as seguintes normas:

- O **Conselho Executivo** é responsável pela aprovação e supervisão da implementação global da política de segurança da informação (PSI).
- O **Chief Information Officer (CIO)** é responsável por assegurar que o SCGP e todos os serviços em nuvem cumprem os requisitos técnicos e legais de segurança, bem como por garantir que os fornecedores são avaliados em conformidade com as normas ISO/IEC 27001, 27002 e 27017, aplicáveis à gestão e segurança da informação em serviços Cloud.
- O **Chief Compliance Officer (CCO)** é o responsável por garantir o cumprimento do Regulamento Geral sobre a Proteção de Dados (RGPD), da lei federal “Health Insurance Portability and Accountability Act” (HIPAA) e sobre as leis locais que se aplicam ao tratamento de dados em nuvem. Nesse sentido, é também responsável pela coordenação das auditorias de conformidade.
- O **Chief Information Security Officer (CISO)** é o responsável pela definição dos controlos técnicos, pela gestão de incidentes e por atuar como ponto de contacto principal em caso de violação de dados. O CISO encarregar-se-á igualmente de dar a conhecer o procedimento de resposta a violações de dados a todos os

utilizadores internos para sempre que possível tomem conhecimento das medidas a seguir caso ocorram violações de dados. Sempre que necessário, o CISO deverá ainda diligenciar para que todos os utilizadores internos tenham acesso a cursos e ações de formação para poderem cumprir os requisitos e obrigações contidos no presente procedimento e na legislação aplicável em matéria de proteção de dados.

- Os **utilizadores internos**, designadamente os profissionais de saúde, deverão aceder exclusivamente à informação estritamente necessária ao desempenho das suas funções, é imperativo que protejam as suas credenciais de acesso de forma rigorosa. Para uma correta identificação de incidentes de segurança que constituam violações de dados é importante que todos os utilizadores internos estejam conscientes da importância e necessidade de saber identificar os que tenham impacto nos Dados Pessoais.
- Os **pacientes** devem assegurar a confidencialidade das suas credenciais e notificar a equipa de segurança, em caso de suspeita de utilização indevida.
- Os **fornecedores de serviços em nuvem** devem, em conformidade com o contrato estabelecido com a organização, implementar medidas de proteção física e lógica nas infraestruturas utilizadas.

5. Diretrizes de Segurança da Informação

Este conjunto de diretrizes define os controlos e medidas de segurança a aplicar, tal como os objetivos a alcançar:

1. Controlos de acesso

- O acesso ao sistema deve seguir o princípio “RBAC (Role Based Access Control)”, segundo o qual os acessos são atribuídos conforme as funções que os utilizadores desempenham.
- Os utilizadores internos do sistema (staff médico, administradores e outros colaboradores) devem autenticar-se usando “Multifactor Authentication (MFA)”.
- Os utilizadores externos devem autenticar-se usando uma “password” forte. É recomendada, mas não obrigatória, a utilização de pelo menos “two factor authentication (2FA)”.
- Nenhum utilizador deve partilhar as suas “passwords” ou métodos de autenticação.
- Os cargos dos utilizadores internos devem ser revistos frequentemente para evitar “role creep”.

- Os utilizadores internos devem seguir os princípios “Clear desk and clear screen”, de modo a evitar o acesso não autorizado a informação privilegiada. Sempre que se ausentam do seu posto de trabalho, os utilizadores devem:

- a) Bloquear o ecrã da sua estação de trabalho.
- b) Desligar a sua estação de trabalho no fim do dia de trabalho.
- c) Informação ou material físico sensível deve ser guardada num local protegido.

- Emails e links externos só devem ser abertos depois de verificados.

2. Proteção da informação

- Toda a informação de estar encriptada usando algoritmos seguros.
- Todo o tráfego de informação deve estar protegido por protocolos seguros.
- A informação deve ser guardada em ambientes Cloud certificados (ISO 27001) e de acordo com o RGPD e o HIPAA.
- Os dados dos pacientes usados para fins de investigação devem ser anonimizados, de modo a garantir que não é possível identificar os pacientes.
- A partilha de informação com entidades externas (companhias de seguros, fornecedores de serviços, etc.) devem seguir um acordo formal previamente estabelecido.
- A informação deverá apenas ser armazenada durante o prazo estabelecido no RGPD. A eliminação desta informação deve seguir parâmetros seguros, de acordo com o RGPD. Depois de eliminada, não deve ser possível aceder a essa informação.

3. Gestão de incidentes

- Todos os incidentes de segurança devem ser comunicados ao CISO, no prazo máximo de 1 hora após a deteção.
- Os incidentes devem ser comunicados à equipa de segurança do fornecedor Cloud.
- Em casos de fuga de dados pessoais dos pacientes, a autoridade competente deve ser notificada, de acordo com o RGPD.
- Após a resolução do incidente, deve ser realizada uma análise ao sistema e devem ser aplicadas as medidas necessárias para evitar reincidências.

- Em casos de incidentes devido a fugas internas, serão aplicadas sanções conforme a gravidade.

4. Formação e consciencialização

- Todos os utilizadores internos devem completar uma formação anual sobre cibersegurança e segurança da informação.
- Devem ser organizadas campanhas internas/externas regulares de modo a consciencializar os colaboradores e os pacientes sobre boas práticas na utilização de sistemas Cloud e gestão de passwords, por exemplo.

6. Requisitos de Segurança

A política de segurança da informação do SCGP estabelece um nível mínimo de proteção para todos os sistemas e operações em ambiente Cloud. É imperativo implementar Firewalls avançadas, monitorização contínua, autenticação segura e aplicar atualizações de segurança sempre que sejam identificadas vulnerabilidades críticas. Relativamente aos fornecedores de serviços em nuvem, é imperativo celebrar contratos que incluam cláusulas específicas de segurança, confidencialidade, auditoria e eliminação segura de dados no termo da relação contratual, bem como garantir a possibilidade de portabilidade dos dados. A política estabelece, adicionalmente, a realização de cópias de segurança automáticas e regulares, armazenadas em locais geograficamente distintos, cifradas e sujeitas às mesmas regras de acesso dos dados originais, com testes periódicos de restauração. Em conformidade com a norma ISO/IEC 27005:2018, a organização deve implementar um processo contínuo de identificação, avaliação e tratamento de riscos de segurança da informação. Este processo deve abranger todos os sistemas, dados e serviços associados à aplicação Cloud de gestão de pacientes, avaliando a probabilidade e o impacto de cada risco identificado. Com base na análise realizada, é necessário definir medidas de mitigação apropriadas, em conformidade com as boas práticas das normas ISO/IEC 27001 e 27002, assegurando uma proteção contínua contra ameaças internas e externas. Os riscos e as respetivas medidas de mitigação devem ser revistos periodicamente, garantindo a melhoria contínua do sistema de gestão da segurança da informação, em conformidade com o ciclo PDCA definido pela ISO/IEC 27001.

7. Penalizações

Os utilizadores devem cumprir integralmente os termos e condições de utilização do software utilizado no âmbito das atividades contratadas pela empresa. Caso se verifique uma violação da presente Política por parte do CIO, CCO, CISO, utilizadores internos, pacientes e fornecedores de Cloud a empresa poderá desencadear os meios legais ao seu alcance e aplicar as penalizações contratuais, bem como revogar imediatamente todos os direitos de acesso aos Sistemas e Tecnologias da empresa por parte do elemento incumpridor, devendo, para o efeito, ser alteradas as respetivas passwords de acesso aos sistemas e desativado o acesso às instalações da empresa.

8. Referências Normativas

1. ISO/IEC 27001:2013. Information technology – Security techniques – Information security management systems – Requirements.
2. ISO/IEC 27002:2013. Information technology – Security techniques – Code of practice for information security controls.
3. ISO/IEC 27017:2015 Information technology – Security techniques – Code of practice for information security controls based on ISO/IEC 27002 for cloud services
4. ISO/IEC 27005—Information security, cybersecurity and privacy protection — Guidance on managing information security risks

2.

A Política de Segurança da Informação (PSI) desenvolvida para o sistema de gestão de pacientes em ambiente Cloud apresenta uma estrutura semelhante às políticas de segurança do Hospital de Braga e do Hospital de Barcelos, encontrando-se alinhada com as normas internacionais mais relevantes de segurança da informação, nomeadamente as ISO/IEC 27001, 27002, 27017 e 27005, bem como com o RGPD e a lei federal HIPAA.

A política em questão apresenta uma forte componente relativa à forma como abrange os princípios fundamentais da segurança da informação, designadamente confidencialidade, integridade, disponibilidade e conformidade legal. Estes princípios são aplicados de forma contextualizada ao ambiente Cloud de gestão de pacientes. A definição clara das responsabilidades (CIO, CCO, CISO, utilizadores internos, pacientes e fornecedores de serviços Cloud) contribui para uma gestão eficaz, assegura a separação de deveres e uma resposta adequada a incidentes, promovendo uma abordagem de segurança em camadas.

A política demonstra igualmente maturidade ao adotar controlos de segurança estruturados, baseados em princípios reconhecidos como o RBAC (Role-Based Access Control) e a aplicação dos princípios “clear desk” e “clear screen”, amplamente utilizados em empresas multinacionais para evitar o acesso não autorizado a informação privilegiada. Estes mecanismos refletem as boas práticas recomendadas pela ISO/IEC 27002 e contribuem para a redução da probabilidade de fuga ou divulgação indevida de informação. Além disso a partilha de informação com entidades externas, incluindo companhias de seguros, instituições de investigação e prestadores de serviços, está sujeita à existência de um acordo formal previamente estabelecido. Este acordo deve definir as responsabilidades, as medidas de segurança e os limites de acesso, de modo a responder às exigências definidas pelo Conselho Executivo.

Outro aspeto relevante é a integração da norma ISO/IEC 27005:2018, que introduz uma perspetiva sistemática de gestão de riscos, particularmente pertinente num sistema de gestão de pacientes em ambiente Cloud. A política estabelece um processo contínuo de identificação, avaliação e tratamento de riscos, permitindo a priorização das ameaças com base no seu impacto e probabilidade, garantindo, deste modo, uma proteção contínua contra ameaças internas e externas. Esta abordagem reforça o ciclo de melhoria contínua (PDCA) recomendada pela ISO 27001, garantindo que a segurança evolui em resposta a novas vulnerabilidades ou alterações tecnológicas.

Em suma, a Política de Segurança da Informação concebida mostra-se abrangente, coerente e tecnicamente bem fundamentada para o contexto de uma aplicação de gestão de pacientes em ambiente Cloud. Esta política está em conformidade com as normas e enquadramentos legais mais relevantes a nível internacional, estabelecendo responsabilidades de forma clara e incorporando controlos adequados à sensibilidade dos dados envolvidos.

[419 palavras]